



DAS Policy

Configuration Management

No:
2100-09

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide **Configuration Management** requirements for Ohio Department of Administrative Services (**DAS**)-managed **Information Systems**. A strong Configuration Management practice will improve security by assisting in **Vulnerability** detection and allowing for faster problem resolution; thereby, restoring **Services** more efficiently. It will also improve overall change management procedures by decreasing the opportunity for the introduction of new incompatibilities or problems, targeting unnecessary duplication and aiding in the identification of potential license issues.

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV. In addition, references to National Institute of Standards and Technology Special Publication 800-53, "Security and Privacy Controls for Federal **Information Systems** and Organizations," family identifiers and control numbers are provided in parentheses next to requirement headers, where applicable.

II. Scope

The scope of this policy includes any DAS-Managed Information System.

This policy also applies to DAS **Data Owners**, **Service Owners**, and extends to managed Service providers.

III. Policy

Configuration Management practices shall be established that include procedures for documenting DAS-Managed Information System configurations and guidance for how configurations are implemented, changed, and maintained. A strong Configuration Management

practice provides a methodology designed to increase the **Integrity, Availability**, and security of DAS-Managed Information Systems.

A. **Baseline Configuration (CM-2)**: All DAS-Managed Information Systems shall have a formal, documented baseline configuration. This configuration is maintained by the applicable operations unit and serves as the baseline for all future builds. DAS-Managed Information System baseline configurations shall contain the following:

1. System components, such as standard software packages installed for workstations, laptops, tablets, servers, mobile devices, etc.
2. Current version numbers of operating systems and software applications
3. Current patch information
4. Configuration settings and parameters
5. Network topology
6. Placement of hardware within the system architecture
7. DAS-Managed Information System baseline configurations shall be documented and maintained for test and development environments.
8. DAS system owners shall document and maintain exceptions to DAS-Managed Information System baselines.
9. Baseline documentation shall be updated, as needed, based on system changes, ranging from minor configuration changes to major system upgrades. DAS-Managed Information System changes shall be approved through a change control board.
 - a) Data Owners and Service Owners shall review established baselines annually or after major DAS-Managed Information System changes (e.g., architectural changes that extend beyond minor patching or minor hardware maintenance, including the addition of new hardware components or software modules and/or major software upgrades; changes that enhance, interrupt or otherwise modify user experience and the way the user interacts with the system; and any change that involves system Availability impacts and/or changes to operational processes).
 - b) Previous baseline configurations shall be retained in accordance with DAS record retention requirements.

B. **Configuration Change Control (CM-3)**: Service Owners shall establish a change control process that includes the DAS Office of Information Security and Privacy's (OISP) review and approval.

1. All changes to DAS-Managed Information Systems shall be reviewed and approved through a change control process.

2. Unapproved changes to DAS-Managed Information Systems shall be prohibited.
 3. Prior to implementing a change, Service Owners shall notify DAS OISP, IT management, data owners and technical teams.
 4. Changes to DAS-Managed Information Systems shall be thoroughly tested, validated, and documented prior to implementation. The documentation shall include evidence of testing, with successful completion.
- C. **Change Control Board:** For DAS-Managed Information Systems, Configuration Management development and implementation responsibilities shall be under the direction of the change control board or other entity as assigned by DAS OIT.
- D. **Security Impact Analysis (CM-4):** DAS IT Operations personnel shall identify proposed changes to DAS-Managed Information Systems that have a potential IT security impact and forward them to the IT security representative on the change control board for evaluation prior to implementation.
- E. **Verification of Security Functions (CM-4):** DAS IT Operations personnel shall verify that approved changes to DAS-Managed Information Systems are implemented correctly, operating as intended, and meeting security requirements.
- F. **Access Restrictions for Change (CM-5):** Only authorized individuals shall be permitted to implement changes, upgrades and/or modifications to DAS-Managed Information Systems.
1. Access control mechanisms shall be employed as outlined in NIST SP 800-53.
 2. DAS OISP Governance, Risk, and Compliance personnel shall conduct compliance monitoring to identify unauthorized changes.
 3. DAS-Managed Information Systems with high or moderate criticality or confidentiality data classification ratings shall be audited annually. DAS-Managed Information Systems with low criticality or confidentiality data classification ratings shall be audited every two years. Refer to Ohio Administrative Policy IT-13, "Data Classification", for additional rating guidance.
 4. Application developers shall be prohibited from having access rights to implement changes or modifications to DAS-Managed Information System production environments unless an exception is approved by DAS OISP.
 5. Only authorized individuals shall have access to implement changes to software resident within software libraries for DAS-Managed Information Systems.

- G. **Least Functionality (CM-7)**: DAS-Managed Information Systems shall be configured to provide only essential capabilities and specifically prohibit the use of unnecessary functions, **Ports, Protocols**, Services, and software.
1. Service Owners shall review DAS-Managed Information Systems periodically to identify and disable any unnecessary and non-secure functions, Ports, Protocols and Services.
 2. Service Owners shall maintain a list of implemented functions, Ports, Protocols and Services used in DAS-Managed Information Systems.
 3. DAS-Managed Information Systems shall employ a deny-all, allow-by-exception policy.
 4. DAS-Managed Information Systems shall conform with the requirements outlined in DAS Standard DAS-ITS-2100-09-A, "Secure Configuration."
- H. **DAS-managed Information System Component Inventory (CM-8)**: The DAS Office of Information Technology (OIT) shall maintain an accurate inventory of components within the **Authorization Boundary** of the DAS-Managed Information System.
1. All configuration items identified and placed under Configuration Management shall be populated and maintained in the state's Configuration Management Database (CMDB). Configuration items shall be current, accurate, and complete; and their relationships to other configuration items maintained appropriately throughout the lifecycle of the configuration item.
 2. Automated mechanisms shall be leveraged, whenever possible, to detect the introduction of unauthorized components into the DAS-Managed Information System, disable network access by such components, and notify DAS OISP personnel of the unauthorized access.
 3. An inventory of components along with a list of personnel responsible for administering the components shall be maintained.
 4. Currently deployed component configurations, with approved deviations, shall be included in the DAS-Managed Information System component inventory.
- I. **Configuration Management Plan (CM-9)**: Service Owners shall establish a Configuration Management plan for DAS-Managed Information Systems that aligns with their change management process. Configuration Management plans shall be maintained by operations personnel, or other entity as assigned by DAS OIT, and shall address:
1. Roles and responsibilities;
 2. Configuration Management processes and procedures;
 3. A process for identifying, defining and managing configuration items;

4. A procedure for placing configuration items under Configuration Management; and
5. A procedure for conducting configuration audits.

J. **Exception Process:** To request an exception to one or more of the requirements outlined in this policy, please complete an IT Security Exception Request form.

1. The form is located within the IT Enterprise Services Portal under the “Services & Products” category.
2. If you have any questions, please contact DAS OISP (refer to Section VII. Inquiries for contact information).

IV. Definitions

- A. Authorization Boundary. All components of an Information System to be authorized for operation by an authorizing official and excludes separately authorized systems, to which the Information System is connected.¹ Also commonly referred to as the Information System boundary.
- B. Availability. Ensuring timely and reliable access to and use of information.²
- C. Configuration Management. A collection of activities focused on establishing and maintaining the Integrity of products and systems, through control of the processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle.³
- D. DAS-Managed Information System. Information Systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- E. Data Owners. The data owner is responsible for the identification and classification of information, in consultation with Legal Counsel, and shall address the assignment of data classification labels, data compilation, data classification coordination, data classification compliance and data access. The role of a data owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, “Data Classification.”

¹ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ Johnson, Arnold, Kelley Dempsey, Ron Ross, Sarbari Gupta, Dennis Bailey. “NIST Special Publication 800-128, Guide for Security-Focused Configuration Management of Information Systems,” U.S. Department of Commerce National Institute of Standards and Technology, October 2019, <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-128.pdf>>.

- F. Information System. A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information⁴ (e.g., servers, workstations, networking components).
- G. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁵
- H. Least Functionality. Devices are configured to allow only the necessary Ports, Protocols, and Services in accordance with functional needs and the risk tolerance in the organization. Open Ports and available Protocols and Services are an inviting target for attackers, especially if there are known vulnerabilities associated with a given port, Protocol, or Service.⁶
- I. Ports. Ports are logical addresses on a computer that allow communication using various Protocols, such as FTP. Ports used in this context should not be confused with the physical serial and parallel Ports used for devices such as printers, scanners and the mouse.
- J. Protocol. A set of rules for assembling and transmitting data over a network.
- K. Security Impact Analysis. The analysis conducted by an organizational official to determine the extent to which changes to the Information System have affected the security state of the system.⁷
- L. Services. The application of business and technical expertise to enable organizations in the creation, management, and optimization of or access to information and business processes.
- M. Service Owner. A Service owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT Services.
- N. Vulnerability. Weakness in an Information System, system security procedures, internal controls, or implementation that could be exploited by a threat source.⁸

V. Authority

ORC 125.18

⁴ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ *Ibid.*

⁶ Johnson, Arnold, Kelley Dempsey, Ron Ross, Sarbari Gupta, Dennis Bailey. “NIST Special Publication 800-128, Guide for Security-Focused Configuration Management of Information Systems,” U.S. Department of Commerce National Institute of Standards and Technology, October 2019, <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-128.pdf>>.

⁷ *Ibid.*

⁸ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-03 Software Licensing	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Standard DAS-ITS-2100-09-A Secure Configuration	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
04/20/2017	Original Policy

Date	Description of Change
06/18/2018	Updated the policy to include additional change and Configuration Management requirements.
12/21/2018	Review of established baselines frequency updated. The exception request language was also modified to align with the current procedure.
06/10/2020	Updated the policy template to align with the current format. Added a reference to DAS-ITS-2100-09-A Secure Configuration Standard.
06/10/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.